PRADITA University

IT40813 · IT Governance, Risk & Compliance

Manajemen Risiko Enterprise dan Risiko TI

Pertemuan 05

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Risiko dan Tujuan
3. Proses ISO 31000
4. Risk Appetite dan Batas
5. Risk Register
6. Matriks dan Kuantifikasi
7. Penanganan dan Risiko Sisa
8. Aktivitas dan Ringkasan

PRADITA University

Register risiko 86 baris. Keputusan mana yang berubah?

Tujuan Pembelajaran

- Menerapkan proses ISO 31000 untuk mengidentifikasi, menganalisis, dan mengevaluasi risiko terkait TI.
- Merumuskan pernyataan *risk appetite* yang dapat dipakai untuk mengambil keputusan.
- Membandingkan penilaian risiko kualitatif dan kuantitatif beserta keterbatasan masing-masing.

Masalah: Daftar Risiko Tidak Mengubah Keputusan

PRADITA University

- Misalkan register Medikara berisi 86 baris dan dibuka dua kali setahun menjelang audit.
- Kontrak vendor Medikara+ diperpanjang, tetapi baris tentang akun vendor tidak dibuka.
- Fakta kasus: kebocoran data skala kecil lewat vendor pada 2025 dan kontrol akses yang lemah.
- Tujuan, skenario, bukti kontrol, dan batas keputusan harus terhubung.
- Detail dan angka tambahan pada contoh adalah pengandaian. Luaran masuk tonggak C2.

Diagram Konsep Bab 5

PRADITA University



Skor matriks berskala urut, bukan rupiah atau peluang. Pemilik risiko tetap bertanggung jawab meski kontrol dikerjakan vendor.

Risiko Berawal dari Tujuan

- ISO 31000:2018: risiko adalah efek ketidakpastian terhadap tujuan.
- Daftar ancaman belum menjadi penilaian risiko.
- ERM menghubungkan pilihan strategi dengan risiko portofolio, bukan sekadar mengumpulkan masalah departemen.
- Analogi ambulans: hujan menjadi risiko bila jalan tergenang dan pasien terlambat ditolong.
- Sekitar 1,2 juta kunjungan per tahun berarti sekitar 3.288 per hari. Misalkan layanan 12 jam: gangguan pendaftaran 3 jam menyentuh sekitar 822 kunjungan.
- Misalkan 216 berkas klinik per tahun. Satu klinik mengubah format: 1 dari 18 berkas bulanan, sekitar 5,6 persen, salah terbaca.

Tujuan, Risiko, dan Keputusan

Tujuan	Skenario	Keputusan
Kerahasiaan data	R-01: akses vendor berlebihan menyebabkan pengungkapan data pasien	Batasi akses dan tinjau AC-01
Kelangsungan pendaftaran	R-03: integrasi BPJS Kesehatan terhenti ketika pasien datang	Siapkan antrean pengganti
Laporan konsisten	R-04: versi spreadsheet berbeda	Tetapkan validasi dan pemilik definisi
Keselamatan pasien	R-11: riwayat alergi tidak terbaca lintas rumah sakit	Libatkan pimpinan klinis dan perbaiki pertukaran data

Risiko berbeda dari temuan. 6 dari 30 akun sampel adalah temuan yang perlu ditutup. Kemungkinan akun itu dipakai mengakses data adalah risiko yang perlu diputuskan.

Lima Komponen COSO ERM

Komponen	Contoh penerapan pada Medikara
Tata kelola dan budaya	Komite 9 anggota, kuorum 6, pemilik risiko wajib hadir
Strategi dan penetapan sasaran	"Satu Pasien, Satu Rekam Medis" menurunkan *risk appetite*
Kinerja	Register 12 skenario dinilai, diprioritaskan, dan diberi keputusan
Tinjauan dan revisi	Insiden 2025 dan temuan audit memicu penilaian ulang R-01
Informasi, komunikasi, dan pelaporan	Indikator dan laporan satu halaman pada Bab 13

Lima komponen dan 20 prinsip, bukan tahap berurutan. Contoh merupakan pengandaian.

Risiko TI di dalam Risiko Enterprise

Tingkat	Pertanyaan	Pemeran	Keluaran
Organisasi	Risiko mana yang menyentuh strategi?	Direksi, komite, kepala risiko	*Risk appetite*, profil risiko
Proses misi dan bisnis	Layanan mana yang terdampak?	Pemilik Medikara+, kepala pendaftaran	*Risk tolerance*, register layanan
Sistem informasi	Kontrol mana yang berjalan?	Kepala operasi TI, pengelola SIMRS	Bukti kontrol, register sistem

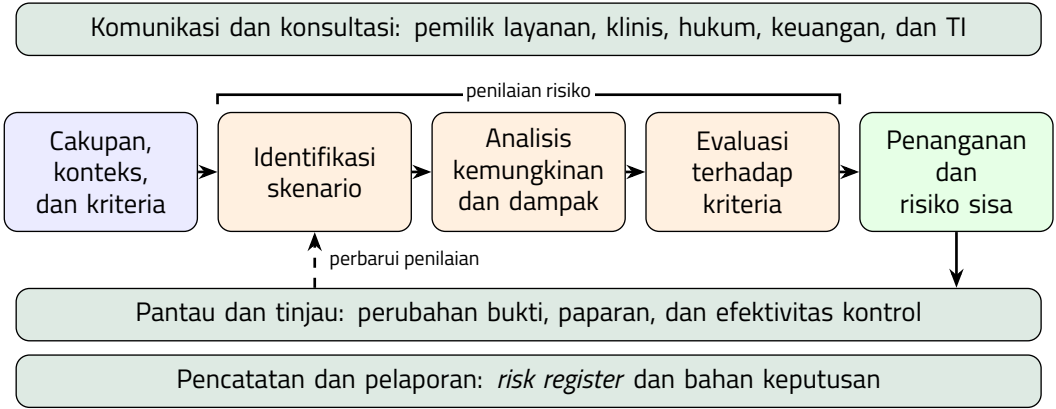
Misalkan 5 rumah sakit mengirim 14 baris per rumah sakit, atau 70 baris. Delapan baris tentang hak akses SIMRS lokal digabung menjadi R-02. Tiga tingkat mengikuti NIST SP 800-39.

Prinsip, Kerangka, dan Proses

PRADITA University

- ISO 31000:2018 memberi panduan, bukan persyaratan sertifikasi organisasi.
- Delapan prinsip: terintegrasi, terstruktur dan menyeluruh, disesuaikan, inklusif, dinamis, informasi terbaik, faktor manusia dan budaya, terus diperbaiki.
- Cakupan, konteks, dan kriteria ditetapkan sebelum penilaian.
- Analogi kendaraan: ban tipis adalah temuan awal, peluang tergelincir adalah analisis, batas aman adalah evaluasi, mengganti ban adalah penanganan.
- Misalkan cakupan Medikara+ 12 bulan: 336.000 janji temu dan 120 akun vendor.

Proses dari Konteks hingga Keputusan



Ringkasan pembelajaran, bukan reproduksi gambar standar.

Kriteria Ditetapkan sebelum Skor

Nilai	Kemungkinan (12 bulan)	Dampak finansial	Dampak layanan
1	Kurang dari 5 persen	Di bawah Rp10 juta	Pulih dalam unit
2	5 sampai kurang dari 15 persen	Rp10 juta sampai kurang dari Rp50 juta	Gangguan lokal
3	15 sampai kurang dari 40 persen	Rp50 juta sampai kurang dari Rp200 juta	Layanan penting tertunda
4	40 sampai kurang dari 70 persen	Rp200 juta sampai kurang dari Rp1 miliar	Gangguan lintas lokasi
5	70 persen atau lebih	Rp1 miliar atau lebih	Layanan utama berhenti

Contoh, bukan skala baku. Skala tidak diubah setelah melihat hasil. Keselamatan dan kepatuhan dinilai pada kolom terpisah.

Mulai dari Peristiwa atau Aset?

Unsur	Berbasis peristiwa	Berbasis aset
Titik awal	Kejadian dan akibatnya pada tujuan	Data, sistem, dan ketergantungan
Contoh	Insiden vendor 2025, gangguan BPJS Kesehatan	Rekam medis, SIMRS, Medikara+
Mudah terlewat	Aset yang belum pernah terkena masalah	Kejadian lintas aset, misalnya satu subpenyedia

- Misalkan 9 skenario dari peristiwa, 8 dari aset, 5 sama: 12 skenario unik.
- NIST SP 800-30 Rev. 1: titik awal dapat membuat risiko terlewat. Sudut pandang kedua meningkatkan ketelitian.

Risk Appetite, Risk Tolerance, Kapasitas

PRADITA University

- *Risk appetite*: arah risiko yang bersedia diambil, dari pimpinan tertinggi.
- *Risk tolerance*: batas operasional yang selalu lebih spesifik.
- Kapasitas risiko: batas yang mampu ditanggung.
- Mampu membayar tidak berarti boleh melanggar kewajiban hukum atau mengabaikan keselamatan.
- Analogi: anggaran perjalanan, batas penyimpangan, dan dana kebutuhan pokok keluarga.

Empat Lapis Batas untuk R-01

PRADITA University

Kapasitas risiko: batas yang mampu ditanggung, misalkan Rp5 miliar per tahun.

***Risk appetite*:** arah yang disahkan direksi. Rendah untuk akses tidak sah pada data pasien. Peluang kerugian Rp1,5 miliar atau lebih paling tinggi 2 persen per tahun.

***Risk tolerance*:** batas operasional. Nol akun vendor aktif tanpa pemilik dan masa berlaku. Pencabutan paling lambat 1 hari kerja setelah penugasan berakhir.

KRI dan bukti: jumlah akun tanpa pemilik, akun melewati masa berlaku, dan hasil AC-01. Nilai di luar batas memicu pembekuan akun dan keputusan pemilik risiko.

Keselamatan pasien dan kewajiban hukum dinilai terpisah, bukan ditukar dengan rupiah.

Usulan Batas Keputusan Medikara (Misalkan)

PRADITA University

Kategori	Arah	Ukuran	Pemicu tindakan
Keselamatan pasien	Tidak menukar risiko cedera berat dengan kecepatan atau biaya	Risiko cedera berat ditinjau dalam 1 hari kerja	Libatkan pimpinan klinis segera
Kerahasiaan	Rendah untuk akses tidak sah pada data pasien	Nol akun vendor aktif tanpa pemilik dan masa berlaku	Bekukan akun yang tidak sesuai
Kelangsungan	Menerima gangguan singkat bila prosedur pengganti berjalan	Pendaftaran terganggu paling lama 2 jam per bulan	Pemilik layanan menyiapkan perbaikan
Kepatuhan	Rendah untuk kewajiban hukum yang terlewat	K-01 sampai K-16 memiliki pemilik; nol baris lewat tenggat	Catat penyimpangan dan tindakan
Finansial	Membatasi kerugian besar	Peluang kerugian Rp1,5 miliar atau lebih paling tinggi 2 persen per tahun	Laporkan ke komite

Menguji Pernyataan Risk Appetite

PRADITA University

- “Tidak menoleransi kebocoran data” belum memberi aturan kerja.
- Empat pertanyaan: menyebut yang diterima dan ditolak? ada ukuran? memicu tindakan dan menyebut pemilik? sejalan dengan kewajiban hukum?
- Contoh NIST, penyedia layanan kesehatan: *risk appetite* rendah untuk kontrol akses yang tidak memadai; 100 persen aplikasi kritis wajib memakai MFA.
- Medikara: 1 dari 120 akun tanpa pemilik, sekitar 0,8 persen, tetap diblokir.
- Denda paling tinggi 2 persen dari Rp500 miliar, yaitu Rp10 miliar, melewati kapasitas pengandaian Rp5 miliar.

Kasus Medikara: Batas yang Disahkan Direksi

PRADITA University

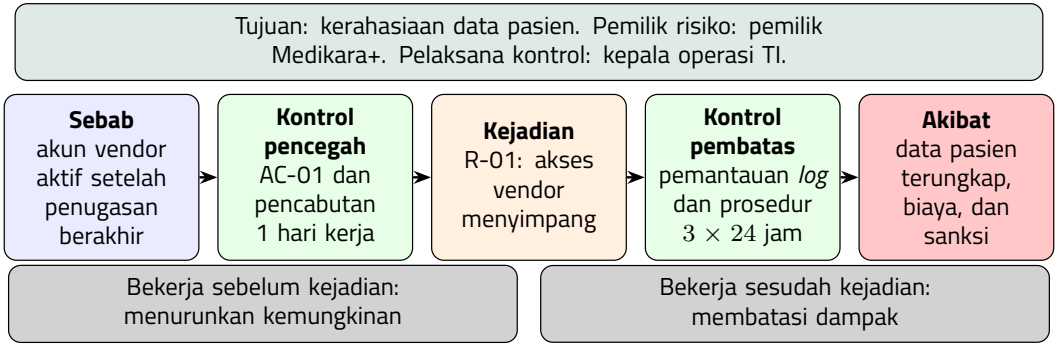
- Misalkan komite membahas batas dengan 7 dari 9 anggota hadir, kuorum 6 terpenuhi.
- Vendor meminta 4 akun tetap aktif 10 hari setelah penugasan berakhir: 40 akun-hari.
- Pemilik Medikara+ menolak dan memberi pengecualian darurat 24 jam: 4 akun-hari, turun 90 persen.
- Konsekuensi pertama: perbaikan vendor lebih lambat, tenggat bergeser 3 hari.
- Konsekuensi kedua: bahasan berpindah ke bukti pengecualian dan pihak yang menyetujui.

Register Menyimpan Alasan Keputusan

PRADITA University

- Satu baris: pengenal, tujuan, sebab, kejadian, akibat, pemilik, bukti, kontrol, penilaian, rencana.
- Pemilik risiko mengelola akibat. Pelaksana kontrol teknis dapat berbeda.
- Analogi buku piutang: jumlah, jatuh tempo, dan penagih membuat catatan berguna.
- AC-01: 6 dari 30 akun sampel dan 24 dari 120 akun, sama-sama 20 persen.
- Pengandaian Bab 4: daftar hanya 108 akun, 12 akun atau 10 persen luput.

Skenario R-01: Sebab, Kejadian, Akibat



Bagian Register Kondisi Saat Ini (Misalkan)

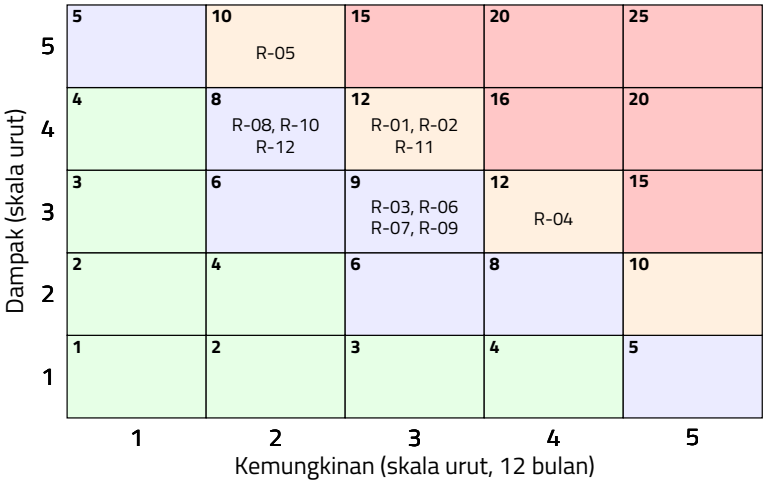
ID dan pemilik	Skenario	Skor	Kontrol dan pemeriksaan
R-01, pemilik Medikara+	Akses vendor berlebihan, data pasien terungkap	$3 \times 4 = 12$	AC-01 belum lengkap; cocokkan 120 akun
R-02, pemilik SIMRS	Hak akses lokal berbeda antar-rumah sakit	$3 \times 4 = 12$	Persetujuan lokal; periksa pencabutan
R-03, kepala pendaftaran	Integrasi BPJS Kesehatan terhenti	$3 \times 3 = 9$	Antrean manual belum dilatih
R-04, kepala pelaporan	Versi spreadsheet berbeda	$4 \times 3 = 12$	Rekonsiliasi bulanan
R-05, pemilik layanan	Cadangan belum diuji, pemulihan gagal	$2 \times 5 = 10$	Cadangan malam; uji pemulihan
R-11, direktur pelayanan	Riwayat alergi tidak terbaca, kesalahan obat	$3 \times 4 = 12$	Keselamatan; tinjauan klinis

Kasus Medikara: Dari 86 Baris ke 12 Skenario

PRADITA University

- 38 baris digabung, 21 baris dipindah ke daftar temuan, 15 baris di luar cakupan: tersisa 12.
- Satu pemilik untuk tiap skenario. Komite dapat membacanya dalam rapat 2 jam.
- Pengenal lama tetap terlacak untuk audit.
- Baris R-01 menulis “AC-01 sebagian”, bukan “AC-01 ada”.
- Data latihan Bab 1 (1.240 rekam, Rp23,7 juta) bukan hasil investigasi: register menulis “belum ada bukti”. Angka lain adalah asumsi pembelajaran.

Matriks Risiko: 12 Skenario Contoh



- 1 sampai 4, rendah
- 5 sampai 9, sedang
- 10 sampai 14, tinggi
- 15 sampai 25, kritis

R-11 berkaitan dengan keselamatan pasien. Skornya sama dengan R-01, R-02, dan R-04, tetapi jalur eskalasinya berbeda.

Skor Sama, Keputusan Berbeda

Skenario	Peluang	Kerugian	Skor	Harapan
R-01 akses vendor	0,2	Rp500 juta	$3 \times 4 = 12$	Rp100 juta
R-04 laporan spreadsheet	0,5	Rp60 juta	$4 \times 3 = 12$	Rp30 juta
R-05 pemulihan gagal	0,1	Rp2 miliar	$2 \times 5 = 10$	Rp200 juta

- Skor berskala urut, bukan rupiah atau peluang. Dampak 4 bukan dua kali dampak 2.
- R-11 dan R-04 sama-sama 12, tetapi hanya R-11 menyangkut keselamatan pasien.
- Analogi: peringkat kedua tidak berlari dua kali lebih cepat daripada peringkat keempat.

Kelemahan Matriks dan Cara Memakainya

PRADITA University

- Cox (2008): resolusi buruk, peringkat dapat terbalik, alokasi sumber daya tidak efektif, masukan dan keluaran perlu tafsir subjektif.
- Thomas dan rekan (2014): struktur matriks menghasilkan keputusan yang arbitrer.
- Penafsiran bab ini: matriks tetap berguna sebagai penyaring dan bahan diskusi.
- Definisikan skala lebih dahulu; pisahkan keselamatan dan kepatuhan.
- Skor sama bukan anggaran sama; hitung lebih lanjut sebelum membeli kontrol.

Kualitatif, Semi-kuantitatif, Kuantitatif

Pendekatan	Bentuk nilai	Kekuatan	Keterbatasan
Kualitatif	Rendah, sedang, tinggi	Mudah disampaikan	Rentang kecil; hasil antarahli berbeda
Semi-kuantitatif	Skala yang maknanya hanya berlaku dalam konteks itu	Perbandingan relatif	Penilaian subjektif dapat tersembunyi
Kuantitatif	Angka yang maknanya terjaga di luar konteks	Mendukung analisis biaya dan manfaat	Asumsi perlu dijelaskan; biaya keahlian

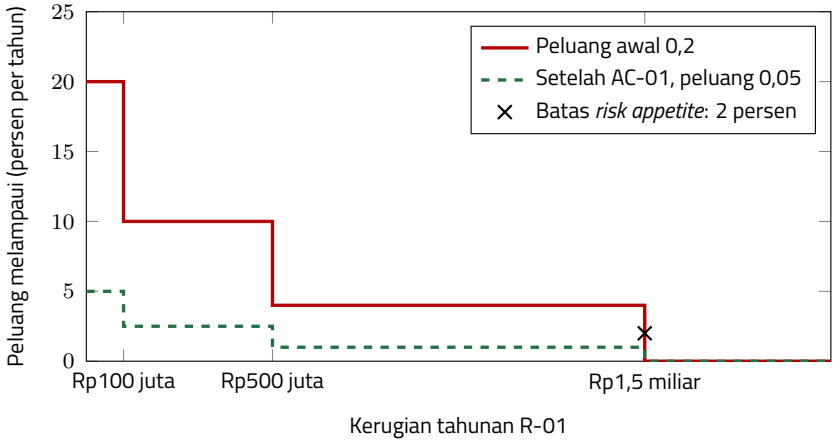
Menurut NIST SP 800-30 Rev. 1. Matriks 5×5 termasuk semi-kuantitatif.

Dua Pertanyaan: Seberapa Sering, Seberapa Besar

PRADITA University

- Misalkan peluang insiden vendor 0,2 per tahun dan kerugian bersyarat rata-rata Rp500 juta: harapan Rp100 juta per tahun.
- Harapan bukan kerugian tahunan. Sebagian besar tahun nol, tahun insiden jauh lebih besar.
- Sebaran per kejadian: Rp100 juta (0,5), Rp500 juta (0,3), Rp1,5 miliar (0,2).
- Tiga titik Rp100 juta, Rp400 juta, Rp1,5 miliar: rata-rata sederhana sekitar Rp667 juta, bobot empat sekitar Rp533 juta.
- Analogi cuaca: peluang hujan 30 persen bukan janji, tetapi tetap berguna untuk memutuskan.

Loss Exceedance Curve R-01 (Misalkan)



Kerugian Rp1,5 miliar atau lebih: 4 persen melewati batas 2 persen; 1 persen di dalamnya.

Asumsi Mana yang Mengubah Keputusan?

Peluang awal	Harapan awal	Harapan sisa	Pengurangan	Biaya	Manfaat bersih
0,1	Rp50 juta	Rp25 juta	Rp25 juta	Rp60 juta	Minus Rp35 juta
0,2	Rp100 juta	Rp25 juta	Rp75 juta	Rp60 juta	Rp15 juta
0,4	Rp200 juta	Rp25 juta	Rp175 juta	Rp60 juta	Rp115 juta

- Titik impas: peluang awal 0,17, atau kerugian bersyarat Rp400 juta pada peluang 0,2.
- Kontrol hanya sampai peluang 0,1: manfaat bersih minus Rp10 juta.
- K-01 tetap berlaku walaupun manfaat finansial negatif.

Pendalaman Teknis (Opsional): Monte Carlo

PRADITA University

- Kolom A dan B `=RAND()`, kolom C menarik 0, 100, 500, atau 1.500 juta rupiah.
- Skrip: `sources/chapter05/simulasi-kerugian.py`, 200.000 tahun, benih 2026.
- Peluang awal: rata-rata Rp100,8 juta; 20,13, 10,06, dan 4,04 persen.
- Setelah AC-01: rata-rata Rp24,3 juta; 4,93, 2,42, dan 0,97 persen.
- Kurva bukan jaminan bahwa kerugian maksimum diketahui.

Empat Pilihan Penanganan R-01 (Misalkan)

Opsi	Contoh keputusan	Hitungan	Bukti dan risiko sisa
Hindari	Tunda pengiriman data berlebih	Tidak dihitung; manfaat layanan ikut hilang	Alur dinonaktifkan; kebutuhan layanan tersisa
Kurangi	Akses terbatas dan AC-01, Rp60 juta per tahun	Peluang 0,2 menjadi 0,05; manfaat bersih Rp15 juta	Bukti pencabutan; akun sah tetap berisiko
Bagi	Klausul tanggung jawab dan asuransi, Rp40 juta per tahun	Peluang tetap 0,2; manfaat bersih Rp20 juta	Cakupan kontrak; kepercayaan pasien tidak berpindah
Terima	Persetujuan direksi sesuai Bab 2	Harapan Rp100 juta; peluang 4 persen melewati batas	Alasan, tenggat, dan kondisi tinjau

Opsi bagi lebih untung Rp5 juta, tetapi skor tetap 12 dan K-01 belum terpenuhi.

Risiko Sisa Dinilai setelah Kontrol Terbukti

Keadaan	Peluang	Skor	Harapan	Manfaat bersih
Saat ini, AC-01 sebagian	0,2	$3 \times 4 = 12$	Rp100 juta	Belum dihitung
Bukti 1 dari 5 rumah sakit	0,17	$3 \times 4 = 12$	Rp85 juta	Minus Rp45 juta
Daftar 108 dari 120 akun	0,065	$2 \times 4 = 8$	Rp32,5 juta	Rp7,5 juta
Sasaran, cakupan penuh	0,05	$2 \times 4 = 8$	Rp25 juta	Rp15 juta

Pengandaian kasar: penurunan peluang sebanding dengan cakupan. Biaya Rp60 juta sudah keluar, tetapi pada cakupan 20 persen skor belum berubah. Risiko sisa aktual semestinya di bawah sasaran.

Pantau dan Tinjau lewat KRI

Indikator	Ambang	Tindakan
Akun vendor aktif tanpa pemilik	Nol hijau; lebih dari nol merah	Validasi 1 hari kerja, lalu bekukan
Akun melewati masa berlaku per bulan	Nol hijau; lebih dari nol merah	Pemilik Medikara+ memeriksa penyebab
Cakupan AC-01 (KCI pada Bab 13)	Minimal 95 persen hijau; 90 sampai kurang dari 95 kuning; kurang dari 90 merah	Periksa kelengkapan daftar akun

Akun melewati masa berlaku naik dari 1 menjadi 5 dalam sebulan memicu pemeriksaan sebelum insiden terulang. Rincian KRI ada pada Pertemuan 13.

Kasus Medikara: Rp60 Juta untuk AC-01

PRADITA University

- Rp60 juta per tahun di bawah batas Rp100 juta: kepala TI memutuskan dengan masukan pemilik layanan.
- Pemilik R-01 tetap pemilik Medikara+. Kepala operasi TI menjalankan AC-01.
- Staf TI mencabut akun paling lambat 1 hari kerja. Audit internal memeriksa kontrol.
- Direksi menerima risiko sisa R-01. Vendor tidak memindahkan akuntabilitas.
- Biaya di atas 10 persen, atau di atas Rp66 juta, kembali ke pemutus awal.

Aktivitas: Tujuan dan Peran

- Tujuan: *risk appetite* tiga sampai empat kategori dan *risk register* 10 sampai 15 skenario.
- Analis risiko memimpin skenario dan menjaga konsistensi skala.
- Anggota akuntansi atau keuangan menilai dampak finansial dan menguji asumsi.
- Analis teknologi menilai kemungkinan dan kontrol; analis regulasi menandai kewajiban.
- Medikara wajib mencakup kebocoran vendor, kontrol akses, integrasi BPJS Kesehatan, dan laporan spreadsheet.

Aktivitas: Luaran C2 dan Berkas

- Isi `risk-appetite.md`, `kriteria-risiko.md`, dan `risk-register.csv` di `sources/chapter05/`.
- Bandingkan dua skenario dengan `analisis-sensitivitas.csv`.
- Serahkan batas risiko, register, dan memo satu keputusan yang berubah.
- Rubrik: skenario dan bukti 30 persen, batas keputusan 30 persen, penanganan 25 persen, asumsi 15 persen.
- Data organisasi nyata wajib berizin dan anonim. Data pribadi pasien tidak boleh dipakai.

Ringkasan

PRADITA University

- Risiko terkait dengan tujuan. Risiko berbeda dari temuan.
- Konteks dan kriteria mendahului skor. *Risk appetite* berguna bila memicu tindakan.
- Kontrol yang direncanakan berbeda dari kontrol yang telah bekerja.
- Matriks membantu diskusi. Model kuantitatif membantu membandingkan biaya dengan asumsi.
- Risiko sisa dinilai setelah kontrol terbukti, lalu dipantau lewat indikator.

Latihan

1. Ubah pernyataan “Medikara tidak menoleransi kebocoran data” menjadi pernyataan *risk appetite* yang realistis dan dapat diukur.
2. Dua risiko sama-sama mendapat skor 12 pada matriks 5×5, tetapi hanya satu yang berdampak pada keselamatan pasien. Jelaskan kelemahan matriks risiko dari contoh ini.
3. Tentukan opsi penanganan yang paling tepat untuk risiko ketergantungan pada vendor aplikasi Medikara+, beserta alasan dan risiko sisanya.

Langkah, tabel contoh, dan lembar hasil ada pada modul.

Bacaan dan Pesan Utama

NIST IR 8286 Rev. 1 dan NIST IR 8286A Rev. 1
NIST SP 800-30 Rev. 1 dan NIST SP 800-39
ISO 31000:2018, COSO ERM, ISO/IEC 27005:2022
Cox (2008), What's Wrong with Risk Matrices?

Penilaian risiko harus mengubah pilihan dan ditinjau ketika bukti berubah.